



AI and POPIA

A guide for South African business owners

What your team's AI tools do with client information,
and what POPIA expects of you.

Your team is probably already using AI.

Someone drafts a client email in a chatbot. Someone pastes a spreadsheet in to "tidy it up". Someone records a meeting and lets an app write the minutes.

None of that is unusual. It is also where client information leaves your business.

This guide is for owners and managers of small and medium businesses who want the basics, without the legal jargon: what AI tools are, what POPIA says about client information, and what to check first.

It takes about ten minutes to read.

WHAT THIS GUIDE IS NOT

It is general information, not legal advice. Your own POPIA adviser should confirm how it applies to your business.

Five parts. One checklist.

Each part matches one of the five areas in the free Maru Online POPIA AI check. Tap a part to jump to it.

1

AI in your business

2

Where client information goes

3

Who can see it

4

Permission and trust

5

If something goes wrong

Read the two short primers first: AI, then POPIA. Then work through the five parts. The last page is a one-page self-check you can print or screenshot.

What "AI tools" means for your business

Four kinds you are probably already using

Chatbots. You type or paste something in and get an answer back. Free and paid versions of the same tool often have different rules about what happens to what you typed.

Assistants inside software you already pay for. Your email, document or meeting software may have AI switched on or on offer.

Meeting note-takers. Apps that join or record calls and write a summary.

Automations. A workflow that sends information from one system to another, sometimes passing it through an AI tool on the way.

What happens when someone types into one

When a person pastes text into an AI tool, that text travels to the company that runs the tool. What that company does next depends on its terms: how long it keeps the text, who can see it, and whether it uses it to improve its product.

You will not find those answers on the screen where you type. They sit in the provider's terms, and they often differ between the free and the business version of the same tool.

THE POINT FOR YOU

The moment client information goes in, it is no longer only inside your business.

PRIMER 2

POPIA in ten minutes

POPIA is the Protection of Personal Information Act 4 of 2013. It sets the rules for how businesses handle information about people.

Personal information is anything that can identify a person: a name, ID number, phone number, email address, account number, address, photo or CV. It can also cover information about a company, where that company can be identified.

Special personal information is a more sensitive group: health, race or ethnic origin, religion, political views, trade union membership, sex life, biometric information, and some criminal information (section 26). It is treated more strictly.

Three roles to know

You are the "responsible party". You decide why and how client information is used, and you stay accountable for it.

A provider that handles it for you is an "operator". An AI tool provider, a cloud service or a payroll company can all be operators.

The person the information is about is the "data subject".
Your client, a staff member, a job applicant.

The eight conditions, in one line each

- 1 **Accountability.** You answer for how the information is handled.
- 2 **Processing limitation.** Use it lawfully, and only what you need.
- 3 **Purpose specification.** Have a clear reason, and say what it is.
- 4 **Further processing limitation.** Don't reuse it for something unrelated.
- 5 **Information quality.** Keep it accurate.
- 6 **Openness.** Tell people how you use their information.
- 7 **Security safeguards.** Protect it, including when others handle it for you.
- 8 **Data subject participation.** People can ask what you hold and ask for corrections.

THE KEY POINT FOR AI

Using a tool does not move the responsibility to the tool's maker. If your staff put client information into it, you remain responsible for what happens to it.

AI in your business

THE QUESTION

Do you know which AI tools your people use, and what goes into them?

Most owners think the answer is "none" or "just a few". In many small businesses it is more than that. People use free tools on their own phones to save time. They do it because the work is pressing, not because they are careless.

AN EXAMPLE (ILLUSTRATIVE)

A bookkeeper at a small firm pastes a client's bank statement into a free chatbot to summarise it. The summary is useful. The statement now sits with a provider the firm has no agreement with.

Why it matters under POPIA. Section 19 requires "appropriate, reasonable technical and organisational measures" to protect personal information, and requires you to identify the risks to it. You cannot identify a risk you do not know about.

FIRST STEP

Ask your team, without blame, which AI tools they use and what for.

Where client information goes

THE QUESTION

When your team pastes client information into an AI tool, where does it go, and what is agreed about it?

Operators need a written contract

Section 21 of POPIA says a responsible party must have a written contract with any operator that handles personal information for it. That contract must require the operator to keep the information secure. The operator must also tell you straight away if it believes someone unauthorised got hold of the information.

A free consumer tool usually has no such contract with your business. A business version often does, or offers one. Always check the provider's current terms. Do not assume.

Going offshore is not banned, but it has conditions

Many AI providers process information outside South Africa. Section 72 of POPIA does not prohibit that. It says you may send personal information to a third party in another country only if one of these applies:

- the recipient is bound by a law, binding corporate rules or a binding agreement that gives similar protection to POPIA
- the person has consented
- the transfer is needed for a contract with the person, or at their request

- the transfer is needed for a contract in the person's interest
- the transfer is for the person's benefit, getting consent is not practical, and they would likely agree

Five questions to ask any AI provider

1. Do you keep what we type in, and for how long?
2. Do you use it to train or improve your product?
3. Who at your company or your suppliers can see it?
4. In which countries is it processed or stored?
5. Will you sign a written agreement covering how our clients' information is handled?

If you cannot get a clear answer to these, treat the tool as unsuitable for client information until you can.

TERMS CHANGE

Check them again when you renew, or when the provider announces changes.

Who can see it

THE QUESTION

Who inside and outside your business can see what goes into AI tools?

Think about three places

- **Shared logins.** One account used by five people means one history everyone can read, and no record of who did what.
- **Meeting recordings and transcripts.** They often contain names, numbers and opinions about people. Where do they sit, and for how long?
- **Connected apps.** An AI tool linked to your email or drive may be able to read far more than you meant to share.

AN EXAMPLE (ILLUSTRATIVE)

A manager connects an AI assistant to the company inbox "to save time". The assistant can now read every client email, including HR and payroll messages.

Why it matters under POPIA. The security duty in section 19 includes keeping information from being accessed unlawfully. Limit access to the people and tools that need it. Special personal information, such as health or biometric data, needs extra care.

FIRST STEP

List who has access to each AI tool, and remove what is not needed.

Permission and trust

THE QUESTION

Do your clients know how their information is used, and did they agree to what you are doing with it?

POPIA expects you to collect information for a clear purpose, tell people what that purpose is, and not use it for something unrelated without a lawful basis.

If your privacy notice says you use client information to deliver their service, using it to test an AI tool for something else may be a stretch.

Automated decisions

Section 71 says a person should not be subjected to a decision with legal consequences, or that affects them substantially, if it is based only on automated processing that profiles them. Profiling covers things like work performance, credit-worthiness, reliability and conduct. There are exceptions, for example where a contract requires it and the person can put their side.

If an AI tool helps you screen job applicants or score clients, a person should make the decision.

AN EXAMPLE (ILLUSTRATIVE)

A business uses an AI tool to rank job applicants, and the tool's ranking is the only thing deciding who gets an interview. That is the kind of use section 71 is aimed at.

Marketing

If you use AI to write and send marketing, section 69 of POPIA still applies. Marketing by email, SMS or similar needs the person's consent, or an existing customer relationship. Every message must say who sent it and give an easy way to stop.

FIRST STEP

Read your privacy notice and ask whether it matches how information is really used today.

If something goes wrong

THE QUESTION

If client information ended up where it should not, would you know what to do?

Section 22 of POPIA says that when you have reasonable grounds to believe someone unauthorised has accessed personal information, you must tell the Information Regulator and the people affected. This must happen as soon as reasonably possible.

Reports to the Regulator are made online, through its eServices portal. They are normally made by your information officer.

Telling the people affected must be in writing. The notice must give them enough to protect themselves, including the likely consequences and what you are doing about it.

Work out the basics before it happens

- Who in your business decides whether something is a breach?
- Who contacts the Regulator, and who contacts clients?
- Where is the record of what you use and who has access?

THE STAKES

The Regulator can issue enforcement notices and administrative fines of up to R10 million (section 109). In practice, the damage to trust usually comes first.

Yes or no? Every "no" is where to look first.

AI IN YOUR BUSINESS

- ☐ I know which AI tools my team uses.
- ☐ Staff know what they may and may not paste into them.

WHERE CLIENT INFORMATION GOES

- ☐ I have checked the provider's terms for any tool that handles client information.
- ☐ There is a written agreement where a provider handles client information for me.
- ☐ I know in which countries the information is processed.

WHO CAN SEE IT

- ☐ Each AI tool has named users, not shared logins.
- ☐ I know which apps my AI tools are connected to.

PERMISSION AND TRUST

- ☐ My privacy notice matches how I use client information today.
- ☐ A person makes any decision that significantly affects someone.

IF SOMETHING GOES WRONG

- ☐ Someone in the business knows how to recognise and report a security compromise.
- ☐ My business has an information officer.

Words you will see

Data subject

The person the information is about.

Information officer

The person in your business responsible for POPIA compliance work. For a private company this is by default the head of the business, and the Information Regulator expects them to be registered.

Information Regulator

The body that oversees POPIA.

Operator

A provider that handles personal information for you.

Personal information

Information that identifies a person.

Responsible party

The business that decides why and how information is used.

Special personal information

Health, race, religion, biometrics and other sensitive categories.

Sources and limits

Sources. Protection of Personal Information Act 4 of 2013, sections 19, 21, 22, 26, 69, 71, 72 and 109. Information Regulator publications and its eServices portal. Bowmans, "South Africa: POPIA considerations in the age of ChatGPT" (12 June 2023).

Correct as at 8 October 2026. Law, guidance and provider terms change. Check them before you rely on this guide.

Not legal advice. This guide gives general information. It does not replace advice from your own legal or POPIA adviser. No supplier can make a business "POPIA compliant". Responsibility stays with your business.



NEXT STEP

See where your business stands.

The free POPIA AI check asks you questions across these same five areas, and sends you a report.

Start the free check

maruonline.com/popia-ai-check

Maru Online

POPIA-conscious AI implementation

hello@maruonline.com · Gauteng, South Africa